MANAGEMENT PREPARATION · GENERAL EDITION

Management security Q&A worksheet

50 practical questions for reviewing the Common foundation and three security options. Answers describe the proposed design, not proof that controls are deployed; unresolved choices and budget limitations are stated explicitly.

50 specific questions | 7 topics | Independent PDF and Markdown

Prepared 25 October 2026 from the current strategy and proposal. Maximum 100 administrators; mandatory 2FA; no new self-managed access servers. Budget answers use the saved starting estimates, not unsaved worksheet edits.

Supporting evidence opens in a new tab, so this worksheet stays at your question. Internal citations and exports refer to this GitHub-deployed edition; external documentation remains unchanged.

> **Before quoting a price:** the saved Option 2 budget starts with CloudFront Business, but the proposed origin failover needs a different plan or pricing model; see the plan qualification and missing-cost discussion.

Worksheet contents

Common foundation and account security

Administrator access and recovery access

Option 1: Lean AWS

Option 2: AWS edge

Option 3: Existing edge

Internal protection and safe changes

Budget, trade-offs and approval

MANAGEMENT Q&A

Common foundation and account security

Q01

What exactly is management approving, and who remains accountable?

- Approve the Common foundation plus one complete protection option, not three overlapping purchases; all options assume at most 100 administrators and mandatory two-factor authentication. [Proposal: Named owners, segregation of duties and a control register] [Proposal: Budget assumptions]
- Name owners for cloud administration, application security, incidents and billing, and require someone other than the change author to approve production work. [Proposal: Named owners, segregation of duties and a control register]
- A RACI responsibility matrix and control register must record the owner, test evidence, accepted exceptions and review dates; AWS operating a service does not transfer these decisions to AWS. [Proposal: Named owners, segregation of duties and a control register] [Proposal: What the team still owns]

Q02

Why separate AWS accounts rather than just use different networks?

- The proposed organization separates management, production, development, security tooling, log archive and backups, with security services delegated to the security-tooling account. [Proposal: One AWS Organization with purpose-built accounts]
- The purpose is to limit the impact of a production or development compromise and keep audit evidence and recovery copies outside application administrators' ordinary control. [Strategy: Account security] [Proposal: An immutable, organization-wide audit trail] [Proposal: Backups that an attacker or administrator cannot delete]
- Management must settle the production-account migration before launch where practical; account separation is an implementation task, not something the organization structure alone completes. [Proposal: One AWS Organization with purpose-built accounts]

Q03

Do SCPs prevent every administrator from overriding security controls?

- An SCP sets the maximum permissions available to users and roles in member accounts, including member-account root users; it does not grant access by itself. [AWS SCP limitations]
- The statement needs limits: SCPs do not protect the management account or restrict service-linked roles, so "no administrator can bypass" is not an organization-wide absolute. [AWS SCP limitations]
- The proposal uses SCPs to deny disabling security services, creating permanent credentials and making unauthorized network changes, with tightly controlled security-automation exceptions. [Proposal: Service control policies that no administrator can bypass]

Q04

How do we avoid locking out legitimate operations with an SCP?

- Deploy the policies in development first, exercise actual deployment and recovery tasks, and follow the proposed week-long test period before production enforcement. [Proposal: Service control policies that no administrator can bypass]
- Explicitly permit required global services when restricting Regions and document the narrowly scoped pipeline or security-automation roles allowed to perform sensitive actions. [Proposal: Service control policies that no administrator can bypass]
- Treat policy simulation as supporting evidence, not a substitute for real workflow tests; any policy change must be reviewed and alerted because the allowed exceptions are security-sensitive. [Proposal: Service control policies that no administrator can bypass] [Proposal: Changes only through reviewed code and keyless pipelines]

Q05

How is the organization management account protected if SCPs do not cover it?

- Keep application workloads out of it and restrict entry to at most two named administrators using IAM Identity Center with hardware-backed authentication. [Proposal: Management account, root users and break-glass]
- Protect the root user with two hardware MFA keys stored separately, no access keys, a documented custody process and an alarm for every use. [Proposal: Management account, root users and break-glass]
- Maintain two controlled emergency identities, alert the security owner whenever either is used, and perform a post-use review rather than treating them as ordinary admin accounts. [Proposal: Management account, root users and break-glass]

Q06

What do resource control policies add beyond user permissions and SCPs?

- RCPs limit access to supported resources, complementing policies that govern what our own identities can do; the proposed perimeter covers services such as S3, KMS, Secrets Manager and SQS. [Proposal: Resource control policies]
- The design denies unapproved outside identities and unencrypted requests where supported, and restricts AWS services acting on resources for another organization. [Proposal: Resource control policies]
- Inventory external access with IAM Access Analyzer before enforcement and explicitly approve necessary integrations such as vendor log delivery; do not assume every service or resource is covered identically. [Proposal: Resource control policies]

Q07

Which insecure defaults are actually removed?

- Enable all S3 Block Public Access settings, encrypted EBS disks and restrictions on publicly shared machine images and snapshots, enforced through organization policies and account baselines. [Proposal: Secure defaults enforced by declarative policies and account baselines]
- Require Instance Metadata Service v2 (IMDSv2), restrict allowed machine-image publishers and apply VPC Block Public Access with documented exceptions for required public-entry and NAT subnets. [Proposal: Secure defaults enforced by declarative policies and account baselines]
- Use mandatory resource tags for ownership, environment and data class, including the tags that trigger backup coverage, and check the resulting resources rather than relying only on the template. [Proposal: Secure defaults enforced by declarative policies and account baselines] [Proposal: Backups that an attacker or administrator cannot delete]

Q08

How do named AWS accounts, roles and two-factor sign-in work?

- Use IAM Identity Center federated to the client identity provider, with Microsoft Entra ID recommended; its own directory is the documented fallback with manual joiner, mover and leaver handling. [Proposal: Named identities through IAM Identity Center with mandatory MFA]
- Require MFA through the actual identity provider and use FIDO2 security keys or passkeys for the most powerful roles, with SMS and email codes disabled in the proposed policy. [Proposal: Named identities through IAM Identity Center with mandatory MFA]
- Use Viewer, Operator, Deployer and Auditor permission sets instead of IAM users, with up to eight-hour ordinary console sessions, one-hour administrator sessions, quarterly access review and inactivity controls. [Proposal: Named identities through IAM Identity Center with mandatory MFA]

Q09

What is logged, and how long do we retain it?

- CloudTrail records account activity, AWS Config records settings, and the shared archive receives load-balancer, edge, network, cluster, database and administrator-access logs. [Proposal: An immutable, organization-wide audit trail]
- The proposed security/audit retention is one year readily available plus six years archived, while operational logs have a shorter 30–90-day window and access logs one year. [Proposal: An immutable, organization-wide audit trail]
- Classify each stream and approve its retention before locking it; the application must also record who changed a guidance object, because infrastructure logs alone do not explain the business change. [Proposal: An immutable, organization-wide audit trail] [Strategy: Data protection]

Q10

Why do we need GuardDuty, Security Hub, Inspector, Config, Access Analyzer and Macie?

- GuardDuty detects suspicious activity, Inspector finds vulnerable software, AWS Config records and checks resource settings, and Security Hub consolidates security findings and standards results. [Proposal: Managed detection with alert-only routing] [Proposal: An immutable, organization-wide audit trail]
- IAM Access Analyzer examines external and unused access, while Macie provides the sensitive-data discovery capability assigned to the central security account in the strategy. [Proposal: One AWS Organization with purpose-built accounts] [Strategy: Account security]
- These tools answer different questions and still require owners to tune findings, choose coverage and fund usage; enabling them is not proof that incidents are handled. [Proposal: Managed detection with alert-only routing] [Proposal: Common cost allowance]

Q11

Who receives an attack alert, and what response is promised?

- P1 pages an on-call phone around the clock, P2 goes to chat and email, and P3 becomes a weekly digest, routed through the proposed Security Hub, EventBridge and SNS process. [Proposal: Managed detection with alert-only routing]
- The design targets P1 acknowledgement within 15 minutes and containment within one hour; these are operating targets to staff and rehearse, not automatic AWS guarantees. [Proposal: Managed detection with alert-only routing]
- Every alert needs a runbook and an owner, and the team tests routing monthly using sample findings so that a paid detection service does not become an unread mailbox. [Proposal: Managed detection with alert-only routing]

Q12

What happens if an attacker deletes the live database or encrypts its data?

- The proposal combines at least seven days of database point-in-time recovery with daily snapshots retained for 35 days and copies in a separate backup account. [Proposal: Backups that an attacker or administrator cannot delete]
- Quarterly restore exercises must prove that the copies, permissions and encryption keys work together, recording recovery time and possible data loss for business approval. [Proposal: Backups that an attacker or administrator cannot delete]
- No fixed recovery-time or recovery-point guarantee is approved by the mere existence of backups; use measured restore results to agree acceptable outage and data-loss limits. [Proposal: Backups that an attacker or administrator cannot delete] [Strategy: Recovery]

Q13

Can an administrator undo a mistaken immutable-backup setting?

- AWS Backup Vault Lock compliance mode has a configurable grace period of at least three days during which the lock can be changed or removed. [AWS backup protection]
- After that period, the lock cannot be changed or deleted while the vault contains recovery points, and protected backups cannot be deleted before their lifecycle completes. [AWS backup protection]
- Before the grace period ends, validate retention, copy jobs and costs, especially any “Always” retention setting; an incorrect immutable policy can create long-lived obligations. [AWS backup protection]

Q14

Does keeping the database in one Region settle data residency and privacy?

- No: the proposal also requires a privacy-impact assessment, a privacy notice, defined retention, reduced device data and documented handling of location information. [Proposal: Data protection and minimization]
- CloudFront serves cached public content worldwide, while Imperva needs explicit contractual commitments about processing and log locations; neither is resolved merely by the database location. [Proposal: Data protection, minimization and what the edge may hold] [Proposal: Protect personal data across both providers]
- Identify what is public, personal or sensitive in responses and logs, and obtain approval for any cross-border processing or retention exception before launch. [Proposal: What the team still owns and the approval condition] [Proposal: Protect personal data across both providers]

MANAGEMENT Q&A

Administrator access and recovery access

Q15

What does Verified Access replace, and what does it not replace?

- It replaces the proposed everyday Client VPN entry path for private administration with application-specific access: one HTTP endpoint for the admin website and two technical endpoints. [Proposal: Administrator console] [Proposal: Engineering access]
- Verified Access evaluates trust-provider data against access policies, with application requests denied until an allow policy is defined. [How Verified Access works]
- It does not replace MFA, AWS permissions, Kubernetes permissions, database credentials or application authorization; those controls remain separate layers. [Proposal: Administrator console] [Proposal: One identity per workload, one login per service]

Q16

Where exactly is 2FA enforced, and is an identity licence included?

- Enforce MFA in IAM Identity Center when it holds the users, or through the federated identity provider's authentication policy; purchasing Verified Access alone does not configure the proposed MFA requirement. [Proposal: Named identities through IAM Identity Center with mandatory MFA] [Proposal: Administrator console]
- For an IAM Identity Center trust provider, AWS requires an organization instance in the same Region as the Verified Access trust provider, so confirm the existing identity deployment before approval. [AWS identity-provider requirements]
- The worksheet reserves USD 300 per month for additional identity licences, based on a placeholder of 100 people at USD 3, not a verified Entra ID quote. [Proposal: Common cost allowance]

Q17

Does the identity-only design verify that an administrator's device is safe?

- Not by itself: the baseline proposal identifies the user and applies access policy, while device posture is a separate trust-provider integration rather than an assumed benefit. [Proposal: Administrator console] [How Verified Access works]
- AWS device trust can require a supported device provider, agent or browser extension, with platform-specific requirements that need testing on the actual administrator machines. [AWS device trust requirements]
- If device checks are made mandatory, price the provider and operational work explicitly and test blocked, unmanaged and recovery devices before enforcing the policy. [AWS device trust requirements] [Proposal: Budget assumptions]

Q18

Why do we need application login and roles after Verified Access has admitted someone?

- Passing the entry policy establishes eligibility to reach the admin application; it does not decide which guidance objects the person may read, edit or publish. [Proposal: Administrator console] [Strategy: Application identity]
- The admin gateway must verify the signed user-context token, while the application retains its own OpenID Connect login and role-based authorization. [Proposal: Administrator console]
- Test users from different administrator groups against real actions and object boundaries, including a valid user attempting an unauthorized update. [Proposal: Twelve go-live gates with evidence, not dates] [Strategy: Gate: administrator login]

Q19

Are administrator countries and obscure hostnames real security controls?

- The design applies administrator location restrictions at the identity provider and Verified Access policy, while the separate, low-visibility hostname reduces casual discovery. [Proposal: Administrator console] [Proposal: Location checks without blocking emergency readers]
- Neither replaces MFA or authorization, and IP-derived location is not reliable evidence of a person's physical location. [Proposal: Location checks with the real client visible at the edge] [Strategy: Location controls]
- Use a documented, time-limited exception process for legitimate travel or unexpected routing, without weakening the mandatory identity checks. [Proposal: Administrator console]

Q20

Does disabling a user immediately terminate every session?

- Do not promise instant revocation: the proposal describes eight-hour administrator-application sessions and warns that a disabled user can retain access until the existing session ends. [Proposal: Administrator console]
- AWS console permission-set sessions are separately configured, including the one-hour privileged limit, and must not be confused with the application-access session. [Proposal: Named identities through IAM Identity Center with mandatory MFA]
- Before approval, test removal from groups, disabled identities, MFA resets and active sessions, and record the maximum observed revocation delay and emergency response procedure. [Strategy: Short sessions] [Proposal: Twelve go-live gates with evidence, not dates]

Q21

How do engineers reach Kubernetes and PostgreSQL without a jump server?

- Use the Verified Access Connectivity Client for a narrowly scoped network endpoint to the private EKS API on port 443 and a database endpoint targeting RDS Proxy. [Proposal: Engineering access]
- Reach Argo CD through kubectl port-forward, keep endpoint security groups restricted, and retain distinct Kubernetes, AWS and database permissions rather than granting broad network access. [Proposal: Engineering access] [Proposal: One identity per workload, one login per service]
- The documented client path is Windows/macOS, with CloudShell VPC environments covering Linux and emergency use; validate the required platforms and Region before removing the VPN. [Proposal: Engineering access] [Proposal: Engineering access]

Q22

Can CloudShell save us if Verified Access or the identity provider fails?

- CloudShell VPC environments provide a managed in-VPC command-line path, but they still require working AWS authentication, permissions and regional service availability. [Proposal: Engineering access] [Strategy: Serverless break-glass]
- An identity-provider outage therefore needs the independently authenticated, MFA-protected emergency identities, not merely a CloudShell bookmark tied to the failed login path. [Proposal: Management account, root users and break-glass] [Strategy: Serverless break-glass]
- Test private network reachability and recovery commands in advance, account for idle-session limits, and retain the VPN until the proposed two-week parallel run and written rollback are complete. [Proposal: Engineering access]

MANAGEMENT Q&A

Option 1: Lean AWS

Q23

What is the complete traffic path in the lowest-cost option?

- Public users reach an internet-facing Application Load Balancer protected by AWS WAF and Shield Standard, then the public gateway and private workloads; there is no full-site edge cache. [Proposal: Public entry] [Proposal: Inside the VPC]
- Administrators use Verified Access to a separate internal load balancer, while technical administrators use the two restricted endpoints rather than the public application path. [Proposal: Administrator console] [Proposal: Engineering access]
- This removes an additional public-edge vendor but sends public demand into the Region, so it is acceptable only after the surge and HTTPS fallback tests pass. [Proposal: Best fit and trade-off] [Proposal: Management approval condition]

Q24

Which attacks will WAF block, and how do we avoid blocking legitimate visitors?

- The proposed rule set combines managed attack signatures, IP reputation, a positive allow-list of public paths and methods, and different rate limits for reads, writes and assets. [Proposal: Public entry]
- Tune thresholds for mobile carriers that put many people behind one address, and use the required COUNT observation period before enforcement rather than enabling aggressive blocking untested. [Proposal: Public entry] [Proposal: Twelve go-live gates with evidence, not dates]
- WAF does not validate whether submitted coordinates are truthful or whether a guidance change is authorized; the application must still enforce those business rules. [Proposal: Location checks without blocking emergency readers] [Proposal: Administrator console]

Q25

Why not block foreign visitors or put CAPTCHA on every public page?

- Emergency readers physically inside the service area can appear to have foreign IP addresses through roaming, so the proposal does not country-block public reads. [Proposal: Location checks without blocking emergency readers]
- Apply stronger scrutiny to suspicious writes and validate coordinates, speed and timestamps in the application, instead of preventing people from obtaining safety information. [Proposal: Location checks without blocking emergency readers]
- Any browser challenge on reads needs accessibility and emergency-load testing; the existing-edge proposal specifically avoids CAPTCHA on public pages and confines attack-time challenge use to the write path. [Proposal: Public entry] [Proposal: Public entry]

Q26

What happens if the directly exposed application cannot handle an emergency surge?

- Shield Standard covers common network/transport attacks, but the proposed drill must test 500,000 simulated public users, a separate population from the maximum 100 administrators. [Proposal: Public entry] [Proposal: Management approval condition]
- The Lean AWS fallback uses DNS failover to a signed static emergency page, and bare S3 website hosting does not supply HTTPS. [Proposal: Detection, response and the emergency fallback in this package]
- A minimal CloudFront fallback or another approved HTTPS solution must be tested and costed, so this option’s starting budget is incomplete until that gap is resolved. [Proposal: Detection, response and the emergency fallback in this package] [Proposal: Management approval condition]

Option 2: AWS edge

Q27

How is Option 2 different from simply adding another WAF?

- CloudFront becomes the public front door and can serve eligible public content from edge locations, while AWS WAF evaluates public requests at that edge. [Proposal: Public entry] [Proposal: Cache public content, never private responses]
- The load balancer is restricted to CloudFront origin-facing addresses and validates a secret origin header, because an address allow-list alone does not identify our distribution. [Proposal: Public entry]
- The proposal also keeps an origin WAF layer in BLOCK, while administrator access remains on Verified Access and off the public CloudFront distribution. [Proposal: Public entry] [Proposal: Administrator console]

Q28

What can be cached, and how do we prevent stale or leaked information?

- Cache approved public assets, map tiles when adopted, and the signed emergency page; do not cache position writes, administrator responses or personalized/private data. [Proposal: Cache public content, never private responses]
- Exclude sensitive requests from caching entirely, rather than merely removing identifying fields from the cache key and risking a shared cached response. [Proposal: Cache public content, never private responses]
- Define the maximum acceptable delay for guidance updates, configure cache rules accordingly, and rehearse invalidation and emergency publishing before launch. [Proposal: Cache public content, never private responses] [Proposal: What the team still owns and the approval condition]

Q29

Will CloudFront failover keep every application feature working?

- No: CloudFront origin failover supports GET, HEAD and eligible cached OPTIONS requests, not POST or PUT, so a static fallback preserves reading rather than the write workflow. [CloudFront origin failover]
- Failover depends on configured errors and timeouts after a primary-origin request fails; it is not a promise of zero interruption or instant switching. [CloudFront origin failover]
- Test both the readable emergency page and the behavior of unavailable writes, including the message users receive and the process for restoring normal service. [Proposal: Detection, response and the edge-served fallback] [Proposal: Twelve go-live gates with evidence, not dates]

Q30

Does the worksheet’s USD 200 CloudFront plan provide the proposed failover?

- No: the current pricing table excludes origin failover from Business and includes it with Premium, listed at USD 1,000 per month, so Business is not a complete fit for the described Option 2. [CloudFront pricing] [Proposal: Compare total edge cost before buying]
- Obtain a Premium or suitably configured pay-as-you-go estimate, validate traffic and feature requirements, and price the separate origin WAF required by the proposal. [Proposal: Compare total edge cost before buying] [Proposal: Public entry]
- Monthly request and transfer allowances are not concurrent-user capacity guarantees; the emergency traffic model and drill remain approval requirements. [CloudFront pricing] [Proposal: What the team still owns and the approval condition]

Option 3: Existing edge

Q31

Why retain Imperva when AWS-only options are available?

- Retain it only if the existing contract supplies valuable protection, incident support or avoided migration work that justifies the total cost. [Proposal: Best fit and trade-off]
- The option keeps Imperva first, AWS WAF at the origin and Verified Access for administrators, while preserving the same internal and account controls. [Proposal: Best fit and trade-off] [Proposal: Contain attacks after the public boundary]
- Require written confirmation of bot management, attack-response commitments, traffic allowances, log delivery and support escalation; a vendor name is not a guarantee that these are purchased. [Proposal: Public entry] [Proposal: Price the contract and the duplicate inspection]

Q32

What stops someone bypassing Imperva and attacking the AWS origin directly?

- The proposed load-balancer security group admits Imperva addresses, and mandatory mutual TLS makes the load balancer verify the origin client certificate. [Proposal: Do not let attackers go around Imperva]
- The origin AWS WAF still enforces the public route allow-list and managed attack rules, with alerts when prohibited paths reach that layer. [Proposal: Do not let attackers go around Imperva]
- Test direct-origin access without the approved client certificate, certificate renewal and trust-store changes; do not approve the option on an IP allow-list alone. [Proposal: Do not let attackers go around Imperva] [Proposal: What management must accept]

Q33

Which layer sees the real visitor IP, and why does it matter?

- With Imperva in front, the origin connection comes from the proxy, so visitor IP reputation and anonymizer filtering belong at the edge that sees the visitor. [Proposal: Visitor checks where the real visitor is visible] [Proposal: Do not let attackers go around Imperva]
- Origin rate and geographic rules must use a trusted forwarded-IP header and reject untrusted header injection; otherwise attackers can distort enforcement and audit records. [Proposal: Do not let attackers go around Imperva]
- This is not unique to Option 3: direct AWS WAF in Option 1 and edge AWS WAF in Option 2 also see visitors at their first public inspection layer. [Proposal: Public entry] [Proposal: Public entry]

Q34

Who handles an incident spanning Imperva and AWS?

- Use one severity and notification process, with vendor and AWS findings routed into the same on-call workflow and each runbook naming the contact and escalation path. [Proposal: One response process across two vendors]
- The contract must cover emergency response and fallback behavior, and the proposed joint exercise must prove the cached emergency page and coordination actually work. [Proposal: One response process across two vendors] [Proposal: What management must accept]
- Record the data-processing terms and residency commitments, including where Imperva holds logs and other traffic data, instead of assuming AWS-side storage settles the whole chain. [Proposal: Protect personal data across both providers]

MANAGEMENT Q&A

Internal protection and safe changes

Q35

What stops a compromised public service reaching the admin plane?

- Keep the EKS API private and separate public and administrator workloads into namespaces with restricted pod settings and default-deny network policies in both directions. [Proposal: Inside the VPC]
- Allow only the needed gateway and service paths, including exact public HTTP routes, and test the implemented network rules using an unauthorized source workload. [Proposal: Inside the VPC] [Proposal: Twelve go-live gates with evidence, not dates]
- Namespaces are an organizational boundary, not proof of isolation by themselves; the proposed policy enforcement and least-privilege workload permissions are what must be demonstrated. [Proposal: Inside the VPC] [Proposal: One identity per workload, one login per service]

Q36

Why give every workload its own AWS identity?

- EKS Pod Identity maps each Kubernetes service account to an IAM role limited to its required secret, key and AWS actions, instead of sharing a powerful role across services. [Proposal: One identity per workload, one login per service]
- A compromised devices service should not obtain the admin backend's secret or database authority, so permission tests must include attempted access to another workload's resources. [Proposal: One identity per workload, one login per service] [Proposal: One identity per workload, one login per service]
- Implement the proposed restrictions on Kubernetes permissions and token mounting without breaking the intended Pod Identity mechanism; validate both the denied access and the application's required credentials. [Proposal: One identity per workload, one login per service]

Q37

How do database roles prevent a public endpoint exposing everything?

- Replace the shared superuser login with separate devices, geometry and admin-backend logins, plus a non-login owner and a migration role used only by the release job. [Proposal: One identity per workload, one login per service]
- Use per-user secrets, RDS Proxy, forced TLS, connection limits and statement timeouts; separate pools help keep a public flood from consuming administrator capacity. [Proposal: One identity per workload, one login per service] [Proposal: One identity per workload, one login per service]
- Reserve master access for emergency use and alert on owner/master logins, then prove the public account cannot list or modify data outside its specific rights. [Proposal: One identity per workload, one login per service] [Proposal: Twelve go-live gates with evidence, not dates]

Q38

Is encryption already covered by HTTPS at the load balancer?

- No: HTTPS at the entry point does not close the plain-HTTP gap between internal services, which the proposal addresses with mutual TLS through Envoy or an ambient mesh. [Proposal: Inside the VPC] [Proposal: Contain attacks after the public boundary]
- Encrypt stored data with environment-specific KMS keys, restrict key access separately from ordinary application administration, and require TLS for database connections. [Proposal: Data protection and minimization] [Proposal: One identity per workload, one login per service]
- Certificate management, key policies and service compatibility are implementation work, so managed edge encryption must not be presented as end-to-end encryption already completed. [Proposal: Inside the VPC] [Proposal: What the team still owns]

Q39

How are releases controlled without storing permanent AWS access keys?

- GitHub Actions assumes short-lived AWS roles through OpenID Connect, with trust restricted to the approved repository, branch, environment and workflow. [Proposal: Changes only through reviewed code and keyless pipelines]
- Reviewed Terraform and Argo CD configuration, permission boundaries, protected branches and independent production approval constrain what an authorized pipeline can change. [Proposal: Changes only through reviewed code and keyless pipelines]
- Temporary credentials reduce standing-secret exposure but do not make a compromised pipeline safe, so changes to workflow files and out-of-process permission changes need protection and alerts. [Proposal: Changes only through reviewed code and keyless pipelines]

Q40

What blocks vulnerable or tampered containers from reaching production?

- The proposal pins hardened Java runtime images by digest, mirrors them through ECR and runs containers non-root with read-only filesystems, reduced capabilities and no debug agent. [Proposal: Hardened images, signed releases and admission control]
- Scanning, software inventories and cosign signatures feed admission rules enforced by Kyverno, which must reject unsigned images and images from unapproved registries. [Proposal: Hardened images, signed releases and admission control]
- The team still rebuilds images and fixes code, with the proposed Critical-patching target tightened for a public exploit, while a tested Argo CD rollback provides recovery from a bad release. [Proposal: Hardened images, signed releases and admission control] [Proposal: Hardened images, signed releases and admission control]

Q41

How are location information, uploads and guidance integrity protected?

- Validate location writes using the service-area polygon, plausible speed and timestamps; remove the unnecessary email field, rotate event identifiers and delete raw locations after the approved event-retention period. [Proposal: Location checks without blocking emergency readers] [Proposal: Data protection and minimization]
- Restrict photos to the admin plane with presigned S3 uploads, malware scanning and a nonpublic bucket, with approved content served through a controlled path. [Proposal: Data protection and minimization]
- Require authorized guidance changes and application audit records, and page the responder when guidance changes outside the approved window rather than relying solely on network attack detection. [Proposal: An immutable, organization-wide audit trail] [Proposal: Detection, response and the emergency fallback in this package]

Q42

Does “no new servers” mean there is no ongoing infrastructure work?

- No additional jump, connector or monitoring server is proposed, but the platform team still operates the existing EKS workloads, nodes, policy enforcement, deployments and administrator devices. [Proposal: What the team still owns] [Proposal: What the team still owns and the approval condition]
- VPC endpoints, Network Firewall egress rules and internal mutual TLS reduce exposure, but they still require configuration, testing, change control and capacity planning. [Proposal: Inside the VPC] [Proposal: Contain attacks after the public boundary]
- Include those managed-service charges and operational tasks when judging complexity and cost; avoiding a server does not make every supporting service free or maintenance-free. [Proposal: Budget assumptions] [Proposal: What the team still owns]

MANAGEMENT Q&A

Budget, trade-offs and approval

Q43

What are the current starting totals for each option?

- Common plus Option 1: USD 2,575.70 monthly, USD 30,908.40 yearly recurring, USD 10,000.00 one-time setup and USD 40,908.40 for the first year including setup. [Proposal: Budget totals]
- Common plus Option 2: USD 2,754.70 monthly, USD 33,056.40 yearly recurring, USD 11,000.00 one-time setup and USD 44,056.40 for the first year including setup. [Proposal: Budget totals]
- Common plus Option 3: USD 3,575.70 monthly, USD 42,908.40 yearly recurring, USD 11,000.00 one-time setup and USD 53,908.40 for the first year including setup. [Proposal: Budget totals]
- These are the worksheet's initial planning scenario, not complete supplier quotes, and the Option 2 feature gap must be corrected before comparing approval-ready totals. [Proposal: Budget assumptions] [Proposal: Compare total edge cost before buying]

Q44

What is inside the Common cost allowance?

- The USD 2,050.00 monthly allowance comprises USD 300 for detection/checks, USD 250 for logs, backups and other usage, USD 1,200 for routine security work and USD 300 for identity licences. [Proposal: Common cost allowance]
- Shared setup is USD 8,000: forty hours at USD 100 plus a USD 4,000 penetration-test/retest allowance, before each option's own implementation estimate. [Proposal: Common cost allowance]
- These are editable planning allowances, not usage measurements or vendor quotations; replace them with actual scope, retention volumes and workload counts before committing spend. [Proposal: Common cost allowance]

Q45

Does the operations allowance purchase 24/7 incident response?

- No: USD 1,200 per month represents twelve hours of routine security work at a USD 100 planning rate and explicitly assumes an existing on-call team. [Proposal: Common cost allowance]
- The operational requirement still includes continuous P1 paging and the 15-minute acknowledgement target, so management must identify who supplies that coverage and who backs them up. [Proposal: Managed detection with alert-only routing]
- If that capability does not exist, add a staffed arrangement or response-service quote rather than treating the twelve-hour allowance as round-the-clock coverage. [Proposal: Budget assumptions] [Proposal: Common cost allowance]

Q46

Which budget omissions could change the preferred option?

- The worksheet excludes or leaves insufficiently scoped existing hosting, load balancers, cluster/database capacity, general delivery, taxes and contingency, and the full cost of networking and security usage still needs validation. [Proposal: Budget assumptions] [Proposal: Inside the VPC]
- Option 1 needs its HTTPS emergency fallback priced, while Option 2 needs the correct CloudFront failover plan and its separately described origin WAF priced. [Proposal: Detection, response and the emergency fallback in this package] [Proposal: Compare total edge cost before buying] [Proposal: Public entry]
- As a sensitivity example only, changing Option 2 from USD 200 to USD 1,000 and adding the worksheet's USD 21 origin-WAF example raises it to USD 3,575.70 monthly, before other gaps. [Proposal: Budget assumptions] [CloudFront pricing]

Q47

What makes the administrator-access bill grow with usage?

- The starting configuration prices one HTTP application and two technical endpoints for 730 hours, totaling USD 489.10 before the separately budgeted administrator WAF and usage allowances. [Proposal: Option 1 budget]
- More applications/endpoints, data processing, additional connections where charged, relevant transfer and identity licences can increase the bill, so 100 administrators alone does not define a total price. [Proposal: Budget assumptions] [Proposal: Cost checkpoint, not a complete quote]
- Use the expected concurrent engineering sessions and transferred data to validate the quote, and confirm deployment-Region support and prices rather than copying the example unchanged. [Proposal: Cost checkpoint, not a complete quote] [Proposal: Engineering access]

Q48

Are the Imperva price and 100-user identity allowance reliable quotations?

- No: Imperva is initially USD 1,000 per month as a clearly labelled placeholder, and identity licences use a USD 300 planning allowance rather than an agreed contract. [Proposal: Option 3 budget] [Proposal: Common cost allowance]
- For Imperva, obtain traffic limits, overages, bot/DDoS capabilities, origin mutual TLS, incident support, log delivery and residency commitments in writing. [Proposal: Public entry] [Proposal: Do not let attackers go around Imperva] [Proposal: Protect personal data across both providers]
- For identity, validate the required authentication features and existing entitlements before replacing the allowance with either a licence quote or zero incremental cost. [Proposal: Named identities through IAM Identity Center with mandatory MFA] [Proposal: Common cost allowance]

Q49

If money is the deciding factor, which option should we choose?

- Treat Option 1 as the lowest-priced starting candidate only if the direct-origin surge test and secure emergency fallback pass; the current partial totals do not prove it has the lowest complete cost. [Proposal: Best fit and trade-off] [Proposal: Management approval condition] [Proposal: Budget assumptions]
- Choose Option 2 when the measured value of caching and edge fallback justifies the corrected plan cost, or retain Option 3 when the contract and avoided migration work justify Imperva. [Proposal: What the team still owns and the approval condition] [Proposal: What management must accept]
- Compare complete costs and operational responsibilities against the same acceptance tests, keeping MFA, authorization, logging and recovery controls rather than deleting them to make a bid look cheaper. [Proposal: Twelve go-live gates with evidence, not dates] [Proposal: Management approval condition]

Q50

What evidence must we see before launch and before retiring the VPN?

- Require evidence for all twelve launch gates, including working login and authorization, blocked forbidden routes, signed-image enforcement, immutable logs and a Security Hub score of at least 95 percent. [Proposal: Twelve go-live gates with evidence, not dates]
- Retest the penetration test with no open Critical or High findings, exercise restoration and surge/fallback behavior, and obtain privacy, retention and residency approval. [Proposal: Twelve go-live gates with evidence, not dates] [Proposal: Backups that an attacker or administrator cannot delete]
- Keep the Client VPN during the two-week parallel access trial with a written rollback, and require management to approve unresolved cost assumptions and measured recovery/access limits rather than only a launch date. [Proposal: Engineering access] [Proposal: Twelve go-live gates with evidence, not dates] [Proposal: Budget assumptions]